WAF

```
{
    "Name": "Capture-Body",
    "Priority": 0,
    "Statement": {
        "RegexMatchStatement": {
            "RegexString": "[\\s\\S]+",
            "FieldToMatch": {
                "Body": {
                    "OversizeHandling": "CONTINUE"
                }
            },
            "TextTransformations": [
                {
                    "Priority": 0,
                    "Type": "NONE"
                }
            ]
        }
    },
    "VisibilityConfig": {
        "SampledRequestsEnabled": true,
        "CloudWatchMetricsEnabled": true,
        "MetricName": "CaptureBody"
    },
    "Action": {
        "Count": {}
    }
}
```



回去重看 log



matchdata 應該會在這邊的 `.matchedData` 裡面

```
.nonTerminatingMatchingRules
    - .ruleMatchDetails
        - .matchedData
```

並且確定封包有通過、沒有被阻擋（而且還有命中規則），但是 MatchData 還是空值



後來看一下文件，它說這個功能是給 SQL injection 跟 XSS 用的，但我用的是 regex_match_statement

terminatingRuleMatchDetails

Detailed information about the terminating rule that matched the request. A terminating rule has an action that ends the inspection process against a web request. Possible actions for a terminating rule include Allow, Block, CAPTCHA, and Challenge. During the inspection of a web request, at the first rule that matches the request and that has a terminating action, AWS WAF stops the inspection and applies the action. The web request might contain other threats, in addition to the one that's reported in the log for the matching terminating rule.

This is only populated for SQL injection and cross-site scripting (XSS) match rule statements. The matching rule might require a match for more than one inspection criteria, so these match details are provided as an array of match criteria.

terminatingRuleType

The type of rule that terminated the request. Possible values: RATE_BASED, REGULAR, GROUP, and MANAGED_RULE_GROUP.

timestamp

The timestamp in milliseconds.

uri

The URI of the request.

這是官方範例，看起來就算命中，也不會把完整的值寫出來

```
        },
        {
            "name": "x-stm-test",
            "value": "10 AND 1=1"
        }
    ]
```

```
{
    "timestamp": 1576280412771,
    "formatVersion": 1,
    "webaclId": "arn:aws:wafv2:ap-southeast-2:123456789012:regional/webacl/test/111",
    "terminatingRuleId": "STMTest_SQLi_XSS",
    "terminatingRuleType": "REGULAR",
    "action": "BLOCK",
    "terminatingRuleMatchDetails": [
        {
            "conditionType": "SQL_INJECTION",
            "sensitivityLevel": "LOW",
            "location": "UNKNOWN",
            "matchedData": [
                "10",
                "AND",
                "1"
            ]
        }
    ],
    "httpSourceName": "ALB",
    "httpSourceId": "alb",
    "ruleGroupList": [],
    "rateBasedRuleList": [],
    "nonTerminatingMatchingRules": [],
    "requestHeadersInserted":null,
    "responseCodeSent":null,
    "httpRequest": {
        "clientIp": "1.1.1.1",
        "country": "AU",
        "headers": [],
        "uri": "",
        "args": "",
        "httpVersion": "HTTP/1.1",
        "httpMethod": "POST",
        "requestId": "null"
    },
```


lambda

最後決定只能在 lambda 當中加上 logger 將所有連到 lambda 的 query 記錄下來，並將 log 存到 s3
接下來就可以觀察 request body 來更方便的上 patch

```
log D SELECT json_extract_string(message,'$.method')    AS method,
             json_extract_string(message,'$.path')      AS path,
             json_extract_string(message,'$.client_ip') AS client_ip,
             json_extract_string(message,'$.status')    AS status,
             json_extract_string(message,'$.body')      AS body
      FROM lambda_logs
      WHERE message LIKE '{%';
   method = POST
     path = /api/v1/validate/code
client_ip = 1.164.178.203
   status = 200
     body = {"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n  pass"}

   method = GET
     path = /api/v1/version
client_ip = 1.164.178.203
   status = 200
     body =
```

- Log fields for protection pack (web ACL) traffic - AWS WAF, AWS Firewall Manager, AWS Shield Advanced, and AWS Shield network security director
- Log examples for protection pack (web ACL) traffic - AWS WAF, AWS Firewall Manager, AWS Shield Advanced, and AWS Shield network security director
- Oversize web request components in AWS WAF - AWS WAF, AWS Firewall Manager, AWS Shield Advanced, and AWS Shield network security director
- AWS WAF provides matched data for regex rules | WafCharm

JA4

可能還需要思考一下 JA4 對我的 rule 真的有用嗎?

- JA4+ Network Fingerprinting • FoxIO Blog

小結

今天在研究能不能讓 WAF 把命中規則的那段內容（matched data）記進 log，方便之後分析攻擊。做法是加一條 Capture-Body 的 rule 去抓 body，但實際看 log 發現，即使封包有通過、也有命中規則，`nonTerminatingMatchingRules` 底下 `ruleMatchDetails` 裡的 `matchedData` 還是空的。查文件才知道 matched data 這個欄位主要是給 SQLi / XSS 的偵測用的，我用的是 regex_match_statement，就算命中也不會將 matchData 列出來、在官方範例也發現，matchata 不會把完整的值寫出來，所以應該是沒辦法用這個方法取得 body，最後透過直接更改 lambda 當中的 FastAPI (後端) 新增了 logger 並將 log 存到 s3，就可以順利的用 duckdb 來觀察 body。

參考資料

- Logging web ACL traffic - AWS WAF
- Log fields for web ACL traffic - AWS WAF
- FoxIO-LLC/ja4（JA4+ 指紋）